

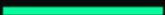
SOC ANALYST LEVEL 1

Practical Security Analysis & Incident First Response

Lecture 7: Alert Triage - Security Alert Analysis

How does a SOC Analyst analyze an alert and decide: Close or Escalate?

Author: Nader Anam | Duration: 3 Hours



Lecture Objectives

Core Concepts

- ✓ Understand the true meaning of Alert Triage.
- ✓ Differentiate between an Alert and an Incident.
- ✓ Distinguish Severity vs. Confidence.
- ✓ Identify required evidence before making a decision.

Practical Application

- ✓ Know exactly when to close an alert (False Positive) vs Escalate to Tier 2.
- ✓ Write professional Initial Analysis reports.
- ✓ Handle common alerts: Failed Logins, Malware, PowerShell, Port Scans.

| Why is Triage Critical? & The Medical Analogy

A Level 1 SOC Analyst's daily job revolves around one critical question: **What do I do with this alert?**

? Close it? Monitor it? Investigate further? Escalate it?

⚠️ **Weak Analysts** make quick decisions without evidence.

★ **Great Analysts** build decisions on evidence, context, and clear analysis.

🏠 The Emergency Room Analogy

Doctors don't operate on every patient immediately. They perform **Triage**:

- Who is critical? (Escalate)
- Who can wait? (Investigate)
- Who is a false alarm? (Close)

The same applies to SOC: Which alert is dangerous? Which needs Tier 2? Which can be safely closed?

| Defining Triage: What it IS and IS NOT

What Triage IS

It is the initial sorting of an alert. The goal is to understand it, collect basic info, assess severity, check context, and make an initial decision (Close/Escalate) with documentation.
It is not a deep forensic investigation, but it's not a superficial read either.

NOT: Quick Closing

Huge Mistake: An analyst sees an alert, doesn't understand it, and immediately closes it. This is dangerous.

Rule: Not understanding an alert is NEVER a reason to close it.

NOT: Escalating Everything

Huge Mistake: Escalating every single alert to Tier 2 without analysis. This wastes time, reduces Tier 2 trust, and causes Alert Fatigue.

Level 1 must provide clear initial analysis before escalating.

| Alert vs. Incident & The 10 Triage Questions

Alert

A single notification requiring investigation. (e.g., 20 Failed Logins)

Incident

A confirmed or highly probable security breach. (e.g., Failed Logins -> Success -> Encoded PowerShell -> External Connection)

The Goal: Answer these by the end of Triage

- ➔ What happened?
- ➔ Who is affected?
- ➔ When did it happen?
- ➔ What is the evidence?
- ➔ What is the context?
- ➔ What is the severity?
- ➔ What is the confidence?
- ➔ Final Decision?

| The Lifecycle of an Alert in the SOC



Phase 1-3: Receipt, Review & Evidence

Read the alert title, identify the source (SIEM, EDR), and determine the type (Auth, Malware). Collect critical evidence: IPs, Hashes, Users, Event IDs.

Phase 4-5: Context & Correlation

Context changes everything. Login from Germany is fine if the user is traveling, bad if they are in Yemen. **Correlation** turns a single alert into an attack story.

| Severity vs. Confidence

Severity (Impact)

The level of danger or potential impact on the organization.

Example: Ransomware is almost always **Critical Severity** due to its destructive nature.

Confidence (Evidence Strength)

The strength and reliability of the evidence indicating a true threat.

Example: A single outbound connection to an unknown IP is **Low Confidence**. Encoded PowerShell -Cz if -- Malicious Hash is .

High Confidence

An alert can be High Severity but Low Confidence, or Medium Severity but High Confidence.

| Proposed Severity Levels

Level	Meaning	SOC Examples
Low	Limited activity or very low risk.	Single failed login, random external firewall block, normal login from known device.
Medium	Suspicious activity requiring review.	Many failed logins, new country login with MFA passed, internal port scan.
High	High probability of a real threat.	Success after failed logins, encoded PowerShell with outbound connection, execution.
Critical	Massive impact or confirmed major incident.	Ransomware, Data Exfiltration, Domain Admin compromised, multiple host infections.

| Understanding False & True Positives

False Positive

Alert triggered, but upon investigation, it is NOT malicious activity.

Ex: Authorized vulnerability scanner triggering a Port Scan alert.

Benign True Positive

Activity is real and alert is technically correct, but the behavior is authorized/safe.

Ex: IT Admin running an approved PowerShell script for maintenance.

Malicious True Positive

Activity is real, and it is highly suspicious or definitively malicious.

Ex: Encoded PowerShell running after opening a phishing email.

| Decision Making: Close vs. Escalate

When to CLOSE

- ✓ No evidence of malicious activity.
- ✓ Activity is confirmed authorized/IT.
- ✓ User confirmed the action logically.
- ✓ No correlated events or impact.
- ✓ **Do not close** just because it's annoying!

When to ESCALATE

- ✗ High or Critical Severity.
- ✗ Multiple correlated indicators (chain).
- ✗ Sensitive account/system affected.
- ✗ Indicators of C2, Persistence, Exfiltration.
- ✗ Success after multiple failures.

| Alert Triage Documentation Template

```
Alert Name: [Alert Title]
Alert Source: [SIEM/EDR]
Date/Time: [Timestamp]
Affected User: [Username] | Affected Host: [Hostname]
Source IP: [IP] | Destination IP/Domain: [Dest]
Process/File/URL: [Indicators]
Observed Activity: [Summary of actions]
Evidence & Related Events: [What else happened?]
Context: [Authorized? Normal?]
Severity: [Low/Med/High/Crit] | Confidence: [Low/Med/High]
Verdict & Decision: [False Positive / Malicious / Close / Escalate]
Recommended Actions: [Next steps]
```

| Alert Analysis: Authentication

Alert 1: Multiple Failed Logins

User: khaled | Failed: 25 | Time: 4 mins | Success After: No | IP: 185.20.40.9

Analysis: Probable Brute Force attempt. No successful login occurred. Severity depends on the account and source.

Severity: Medium

Confidence: Medium

Decision: Investigate/Monitor. Escalate ONLY if a success occurs or account is highly sensitive.

Alert 2: Failed THEN Successful Login

User: finance.manager | Failed: 18 | Success: Yes | Logon Type: 10 (RDP) | Time: 01:40 AM

Analysis: Highly suspicious. Brute force followed by success on a sensitive financial account via RDP at night.

Severity: High

Confidence: High

Decision: Escalate to Tier 2. Possible Account Compromise. Reset password immediately.

| Alert Analysis: Endpoint Malware

Alert 3: Malware Blocked

File: invoice_update.exe | EDR Action: Blocked | Execution: No | Network: None

Analysis: Threat is real but EDR successfully blocked it. No execution or outbound connections.

Severity: Medium

Confidence: High

Verdict: True Positive Blocked. Decision: Close/Investigate lightly (check email source, verify quarantine).

Alert 4: Malware Executed

File: invoice_update.exe | Path: AppData | EDR Action: Allowed | Execution: Yes | Conn: 91.200.10.5

Analysis: The file ran from a suspicious path and established outbound communication. EDR failed to block.

Severity: High

Confidence: High

Verdict: Malware Execution with C2. Decision: Escalate and isolate host immediately.

| Alert Analysis: Anomalies & PowerShell

Alert 5: Login from New Country

User: ali | Country: Germany | Prev: Yemen | MFA: Passed | Device: Unknown

Analysis: New country and unknown device. MFA passed, but could be a stolen session token.

Severity: Medium

Confidence: Low/Med

Decision: Investigate. Verify travel status with user. Check impossible travel logs.

Alert 6: Suspicious PowerShell

Parent: winword.exe | Cmd: powershell -enc aQBIA... | Conn: Outbound 443 | EDR: Allowed

Analysis: Word spawning encoded PowerShell with outbound traffic is classic phishing-led C2 execution.

Severity: High

Confidence: High

Decision: Escalate to Tier 2. Decode command safely, check network logs, isolate host.

| Alert Analysis: Network Recon & Evasion

Alert 7: Internal Port Scan

Src: 10.0.0.55 | Dest Range: 10.0.0.1-254 | Ports: 22,80,443,445,3389 | Scanner: Unknown

Analysis: Internal host scanning multiple ports rapidly. Could be IT, Vuln Scanner, or a compromised host doing Discovery.

Severity: Medium

Confidence: Medium

Decision: Investigate. Check owner of 10.0.0.55, check if scan was scheduled/approved.

Alert 8: Audit Log Cleared

Event ID: 1102 | Host: DC-01 (Domain Controller) | User: admin | Time: 03:05 AM

Analysis: Clearing logs on a critical Domain Controller by an admin out of hours is a massive Defense Evasion indicator.

Severity: Critical

Confidence: High

Decision: Escalate immediately. Check SIEM logs before deletion, notify IR team.

| Alert Analysis: Phishing & Data Loss

Alert 9: Phishing Report -> Execution

User: mona | File: invoice.docm | Action: Opened | Endpoint: winword launched powershell -> Outbound

Analysis: The phishing attempt was successful. Code execution occurred on the endpoint with outbound comms.

Severity: High

Confidence: High

Decision: Escalate. Analyze attachment safely, isolate endpoint, block malicious domain.

Alert 10: Possible Data Exfiltration

Host: FIN-PC-03 | Dest: 185.20.40.9 | Bytes Sent: 4.5 GB | Prev Alert: Suspicious Login

Analysis: Massive outbound data transfer to external IP following a suspicious login on a finance machine.

Severity: Critical

Confidence: High

Decision: Escalate immediately. Identify data type, preserve evidence, initiate IR procedures.

| Writing a Professional Initial Analysis

Initial analysis must be: **Brief, evidence-based, without exaggeration, with a clear verdict and recommendation.**

✗Bad Example

"The attack is very dangerous and we must escalate because there is a virus and I don't know what it is."

✓Professional Example

"The alert shows 18 failed login attempts followed by a successful RDP login for a privileged user from an external IP at 01:40 AM. This pattern suggests possible account compromise and requires immediate escalation."

Professional Phrases to Use:

"The activity indicates...", "The evidence suggests...", "Possible account compromise...", "No evidence of successful execution was found...", "Escalation is recommended due to..."

| Decision Templates

Close Decision Template

Alert Name: Internal Port Scan
Reason for Closure: Benign True Positive
Evidence Reviewed: Traffic originated from 10.0.0.55
User/IT Confirmation: Approved Vulnerability Scanner
Final Verdict: Benign True Positive
Notes: Closed as activity occurred during scheduled scan window. No follow-up malicious activity observed.

Escalation Template

Alert Name: Suspicious Auth & PowerShell
Reason for Escalation: Account Compromise + Execution
Key Evidence: 18 failed attempts -> RDP Success -> Encoded PS
Severity: High | Confidence: High
Observed Timeline: Brute force followed by C2 execution.
Escalated To: Tier 2 / IR Team

| Practical Labs 1 & 2

Lab 1: Failed Logins (Ahmed)

30 failed attempts | Ext IP | Success: No | MFA: Enabled

Sec: Med Conf: Med
| Decision: Monitor

"User experienced 30 failed attempts. No success observed, MFA enabled. Indicates brute force but no compromise. Continued monitoring recommended."

Lab 2: Suspicious PS (Sara)

Parent: excel.exe | Cmd: -enc SQBFAFgA | Conn: 443 every 60s

Sec: High Conf: High
| Decision: Escalate

"Excel launched encoded PS, followed by repeated outbound connections every 60s. Suggests phishing execution and C2 beaconing. Escalate immediately."

| Practical Labs 3 & 4

Lab 3: Malware Blocked (Omar)

File: report_viewer.exe | EDR Action: Blocked | Execution: No

Decision: ~~Close/Investigate~~

Not a False Positive, it's a **True Positive Blocked**. Verify quarantine, check source, and document no execution occurred.

Lab 4: New Country (Manager)

Country: Netherlands | MFA: Passed | Impossible Travel: Yes | Rule: Forward all emails to external

Decision: ~~Escalate~~

MFA Passed is NOT enough to close because of Impossible Travel and a malicious Mailbox Rule. Reset password and revoke tokens.

Full Training Scenario & MITRE Mapping

Scenario: finance.manager on FIN-LAPTOP-03

22 Failed Logins -> Success RDP -> Event 4672 (Privileges) -> Excel runs encoded PS -> DNS query to payroll-check-update.example -> Outbound 443 every 60s -> Scheduled Task created -> SMB to FILE-SRV-01.

Event	MITRE ATT&CK Tactic
Failed Logins / RDP Success	Credential Access / Initial Access
Event 4672 / Excel -> PS	Privilege Escalation / Execution
DNS Query + Traffic every 60s	Command and Control (C2)
Scheduled Task / SMB Traffic	Persistence / Lateral Movement

"The alert shows 22 failed logins followed by a successful RDP login. Special privileges were assigned and Excel launched encoded PowerShell. The host established repeated C2 connections, created a Scheduled Task, and attempted SMB lateral movement. Escalation to Tier 2 is required." (Decision: Escalate | Sev: High | Conf: High)

| Common Mistakes & The Golden Rule

Common Mistakes

- ✗ Judging only by the alert name.
- ✗ Closing without evidence.
- ✗ Ignoring context / sensitive accounts.
- ✗ Missing the "Success after Failure" link.
- ✗ Confusing Severity and Confidence.

The Golden Rule

Don't say: "The alert is dangerous."

Say: "The alert is dangerous because there were 18 failed attempts followed by an RDP success from an external IP, leading to encoded PS execution."

Don't say: "The alert is normal."

Say: "Closed because activity originates from an approved internal scanner during a scheduled window, with no follow-up indicators."

| Homework & Next Lecture

Homework Assignment

Alert: Suspicious Login & Endpoint Activity | User: hr.manager | Host: HR-LAPTOP-07

Events: 15 Failed Logins (Ext IP) -> Success RDP -> Event 4672 -> winword runs encoded PS -> DNS to document-update-check.example -> Outbound 443 every 60s -> Scheduled Task "OfficeUpdate" -> SMB to FILE-SRV-02.

Task: Provide Severity, Confidence, MITRE tactics, Decision, and write a 6-8 line Initial Analysis.

Instructor Notes

Make this interactive. Do not accept "Close" or "Escalate" without evidence. Focus heavily on Context and writing the Initial Analysis properly.

Next Lecture

Lecture 8: Phishing Email Analysis

Headers, Links, Attachments, SPF/DKIM/DMARC, User Actions.